

CyberEval: A Multi-Dimensional Framework for Evaluating LLM Security Knowledge and Reasoning

Anonymous Authors

Anonymous Institution

Abstract. As Large Language Models (LLMs) are increasingly deployed in security-critical applications—from vulnerability triage and threat intelligence to incident response and compliance auditing—thorough evaluation of their security knowledge and reasoning capabilities becomes essential. Existing benchmarks evaluate narrow slices of security competence: CyberSecEval [1] focuses on secure coding, CyberMetric [4] on factual knowledge via multiple-choice questions, and CTF benchmarks [5] on offensive skills. None captures the full spectrum of competencies required for effective security assistance across organizational workflows. We present CYBEREVAL, a multi-dimensional evaluation framework that assesses LLMs across seven security competency dimensions aligned with the NICE Cybersecurity Workforce Framework [7] and CISSP domains [8]: Vulnerability Knowledge (VK), Threat Intelligence (TI), Secure Coding (SC), Incident Response (IR), Compliance & Governance (CG), Forensic Analysis (FA), and Security Architecture (SA). Our framework comprises 4,231 evaluation items spanning four assessment formats: multiple-choice questions, code analysis tasks, scenario-based assessments, and open-ended reasoning problems, each calibrated to three difficulty tiers using Item Response Theory (IRT) [26]. We evaluate 10 contemporary LLMs and establish competency profiles revealing highly uneven capabilities across dimensions. GPT-4o achieves the highest aggregate score (71.4%) but scores only 48.2% on Security Architecture and 52.7% on Compliance. Open-source models show surprising strength in Vulnerability Knowledge (Llama-3-70B: 64.8%) but significant weakness in Incident Response (39.1%). We provide competency gap analysis, dimension-level error taxonomy, and actionable recommendations for model improvement. CYBEREVAL is released as an open evaluation pla... [truncated]

Keywords: Security Evaluation · LLM Assessment · Cybersecurity Benchmark · Competency Framework · Multi-Dimensional Evaluation

1 Introduction

The integration of Large Language Models into cybersecurity workflows picked up pace since 2023, with organizations deploying LLMs for vulnerability analysis [14], threat intelligence summarization [18], incident triage, compliance auditing, and security architecture review [17]. A 2024 SANS Institute survey found

that 67% of security operations centers have experimented with LLM-assisted tooling, yet 78% reported uncertainty about model reliability across different security tasks. This uncertainty stems from a fundamental gap: existing evaluation frameworks do not capture the breadth of capabilities required for effective security assistance.

Current security benchmarks suffer from three critical limitations. First, **narrow scope**: CyberSecEval [1] evaluates secure coding and cyberattack compliance but does not assess threat intelligence interpretation, incident response reasoning, or governance knowledge. CyberMetric [4] provides multiple-choice questions across cybersecurity topics but lacks scenario-based assessment of reasoning depth. CTF-oriented benchmarks [5,9] evaluate offensive capabilities in isolation. Second, **format bias**: most benchmarks rely primarily on multiple-choice questions (MCQ), which test pattern recognition rather than the multi-step reasoning required in real security workflows [10]. Third, **missing calibration**: without difficulty calibration across dimensions, cross-dimensional comparison is unreliable—a model scoring 70% on an easy Secure Coding assessment and 60% on a difficult Forensic Analysis assessment may actually be weaker in coding than forensics. Recent work on IRT-based benchmark calibration [27] shows that proper calibration enables dramatically more efficient and reliable evaluation.

CYBEREVAL addresses these gaps through four specific contributions:

1. **A 7-dimensional competency framework** aligned with the NIST NICE Cybersecurity Workforce Framework (SP 800-181r1) [7] and the eight CISSP domains [8], covering the full spectrum of organizational security needs.
2. **Multi-format assessment** using four item types—MCQ, code analysis, scenario-based, and open-ended reasoning—with difficulty calibrated via 3-parameter Item Response Theory (IRT) [26].
3. **Competency profiling with gap analysis**: radar-chart visualizations and quantitative gap scores enabling targeted model selection for specific security workflows.
4. **Reproducible automated evaluation**: deterministic scoring pipelines with human-validated answer keys and inter-annotator agreement of $\kappa = 0.87$ for open-ended items.

2 Related Work

2.1 General LLM Evaluation Frameworks

The evaluation of LLMs has matured rapidly. HELM [11] introduced holistic evaluation across 42 scenarios covering accuracy, calibration, robustness, fairness, and efficiency, establishing the principle that single-metric evaluation is insufficient. MMLU [12] established multi-task evaluation across 57 academic subjects, including a narrow “computer security” category with only 100 questions—far too few for reliable security assessment. BIG-bench [13] compiled 204 tasks from 444 authors but includes minimal security-specific evaluation. Chang et al. [10] provide a comprehensive survey of LLM evaluation methodologies, identifying the

need for domain-specific benchmarks that go beyond aggregate metrics. These general frameworks demonstrate the importance of multi-dimensional evaluation but lack the domain depth required for cybersecurity assessment.

More recently, Polo et al. [27] demonstrated that IRT-based calibration enables evaluation with dramatically fewer items while maintaining reliability, achieving 95% rank correlation with full benchmarks using only 100 items. Martinez-Gil [28] provided a systematic analysis of how IRT models from psychometrics can be adapted for AI evaluation, addressing the fundamental question of whether AI “ability” is a coherent construct analogous to human cognitive ability.

2.2 Security-Specific LLM Benchmarks

CyberSecEval [1] from Meta evaluates LLMs on two axes: propensity to generate insecure code (across 8 CWE categories and 189 test cases) and compliance with cyberattack requests. It found that more capable models paradoxically suggest more insecure code—Code Llama 34B produced insecure suggestions 33% of the time. CyberSecEval 2 [2] extended this with prompt injection and code interpreter abuse tests. CyberSecEval 3 [36] further added autonomous cyber operations evaluation, including an automated CTF testing framework and visual prompt injection testing. While pioneering, the CyberSecEval series focuses on code generation safety and offensive compliance rather than the breadth of security knowledge and reasoning.

CyberMetric [4] offers 80, 500, 2,000, and 10,000 question variants generated via RAG from NIST standards, RFCs, and security publications. Human experts invested 200+ hours validating questions. Evaluation of 25 LLMs found GPT-4o and Mixtral-8x7B-Instruct among the strongest performers. However, CyberMetric relies exclusively on MCQ format, testing factual recall rather than applied reasoning.

NYU CTF Bench [5] provides a scalable dataset of 256 Capture-the-Flag challenges derived from NYU CSAW competitions for evaluating LLMs in offensive security. Using automated frameworks with tool-calling capabilities, it evaluates five LLMs on web exploitation, cryptography, reverse engineering, and forensics categories. **Cybench** [6] provides 40 professional-level CTF tasks with subtask decomposition for fine-grained capability analysis, finding that even frontier models solve fewer than 10% of professional-level challenges without assistance. **InterCode** [9] standardizes interactive coding benchmarks including a CTF component with execution feedback. These benchmarks evaluate offensive capabilities but do not assess defensive, governance, or architectural knowledge.

SecurityEval [19] provides 130 Python code samples across 75 CWE types for evaluating code generation security. **SecBench** [21] provides a comprehensive multi-dimensional benchmarking dataset covering 11 cybersecurity domains with both MCQ and short-answer formats, benchmarking 16 best-performing LLMs across 3,375 questions. **CTIBench** [22] evaluates LLMs on 5,610 cyber threat intelligence samples across five subtasks including CVE analysis, MITRE ATT&CK mapping, and threat report summarization. While comprehensive in

their respective scopes, none of these benchmarks provides the IRT-calibrated, multi-format competency profiling that CYBEREVAL offers.

2.3 LLM Security Capabilities and Risks

Pearce et al. [14] conducted the first systematic evaluation of GitHub Copilot’s security, finding that 40% of generated programs contained vulnerabilities across 25 CWE scenarios. Perry et al. [15] showed in a controlled user study ($n = 47$) that developers with AI assistants produced significantly less secure code while believing it to be more secure—a dangerous “false confidence” effect. Fang et al. [16,17] demonstrated that LLM agents can autonomously hack websites and exploit one-day vulnerabilities, raising dual-use concerns. Deng et al. [23] introduced PentestGPT, an LLM-empowered penetration testing tool evaluated at USENIX Security 2024 that showed LLMs can effectively guide penetration testing when combined with structured reasoning modules. Happe and Cito [24] provided an early empirical study of LLM-guided penetration testing on Linux systems at ESEC/FSE 2023.

Zhang et al. [18] provide a systematic literature review of 300+ works on LLMs in cybersecurity, covering 25 models and 10+ downstream tasks, identifying a critical gap between narrow benchmark evaluation and real-world security deployment requirements. The SECURE benchmark [25] evaluates LLMs as cybersecurity advisory tools, finding that models show uneven advisory capabilities across vulnerability types.

On the dual-use assessment front, the WMDP benchmark [29] measures hazardous knowledge in biosecurity, cybersecurity, and chemical security domains, proposing unlearning as a mitigation approach. Phuong et al. [30] from Google DeepMind introduced a framework for evaluating frontier models for dangerous capabilities including cyber-offense, persuasion, and self-proliferation. Zou et al. [31] demonstrated universal adversarial attacks on aligned LLMs via the GCG method, while Mazeika et al. [38] proposed HarmBench as a standardized framework for automated red teaming evaluation with 510 harmful behaviors. The NIST AI Risk Management Framework [33] provides governance guidance specifically addressing generative AI risks including cybersecurity dual-use.

2.4 Emerging Evaluation Paradigms

Several concurrent works address aspects of our evaluation goals. CyberBench [35] aggregates multiple existing cybersecurity benchmarks into a unified multi-task evaluation, testing across knowledge, reasoning, and action. While sharing our multi-task philosophy, CyberBench combines existing benchmarks rather than designing items to a unified difficulty scale. CyberSecEval 3 [36] extends Meta’s evaluation suite with autonomous offensive capabilities and prompt injection resistance, advancing beyond code-level assessment but still focusing primarily on attack/defense rather than organizational security competencies.

EnIGMA [37] introduces an enhanced interactive agent framework for CTF challenges, demonstrating that agentic architectures significantly outperform

single-pass LLM evaluation in offensive security tasks. This raises an important methodological question: should security evaluation benchmark the model alone or the model-plus-tools system? CYBEREVAL evaluates standalone model knowledge as the foundation, but we acknowledge that real-world deployment involves tool augmentation.

SecQA [42] provides a concise QA dataset evaluating security knowledge, finding significant performance variation across models on targeted security questions. SecCodePLT [47] offers a unified platform specifically for evaluating code generation security, complementing our SC dimension with deeper code-level analysis. LLM4Vuln [46] decouples vulnerability reasoning into sub-capabilities (detection, classification, interpretation), providing finer-grained analysis within the vulnerability domain than our VK dimension.

2.5 Certification-Based Evaluation

An emerging approach evaluates LLMs against established cybersecurity certification exams. Mavruk and Demartini [40] evaluate LLMs on four major certifications (CompTIA Security+, CEH, CISSP, CISM), finding that GPT-4 passes Security+ and CEH but fails CISSP and CISM—consistent with our finding that governance and architectural knowledge lag behind technical knowledge. Park and Ferragut [41] similarly find that LLMs struggle with CISA (audit-focused) exam questions, particularly those requiring organizational context and regulatory interpretation. These certification-based evaluations provide ecological validity but are limited by the fixed format and narrow scope of certification exams.

2.6 Safety and Red-Teaming Evaluation

While distinct from security *knowledge* evaluation, safety benchmarks provide methodological insights. HarmBench [38] establishes a standardized framework for automated red teaming, demonstrating the importance of adversarial evaluation protocols. WildTeaming [39] scales red-teaming using in-the-wild jailbreak techniques collected from online forums. R-Judge [43] evaluates safety risk awareness in LLM agents, testing whether models can identify when tool use could cause harm—a capability relevant to our IR and SA dimensions. SafetyBench [44] provides a large-scale MCQ safety evaluation across multiple languages, informing our multilingual extension plans. AutoAttacker [45] shows that LLMs can orchestrate multi-step cyber-attacks autonomously, underscoring the dual-use nature of security capabilities we evaluate.

Huang et al. [48] provide a systematic review of domain-specific LLM evaluation methodologies, identifying key design principles including multi-format assessment, difficulty calibration, and construct validity—all of which inform CYBEREVAL’s design.

Table 1: Comparison of cybersecurity LLM benchmarks. Dims = security dimensions assessed. Formats: M = MCQ, C = code analysis, S = scenario, O = open-ended.

Benchmark	Dims	Items	Formats	Calibrated	Profiling
CyberSecEval [1]	2	189	C	✗	✗
CyberSecEval 3 [36]	4	500+	C	✗	✗
CyberMetric [4]	1	10,000	M	✗	✗
NYU CTF Bench [5]	1	256	C	✗	✗
Cybench [6]	1	40	C	✗	✗
SecBench [21]	11	3,375	M,S	✗	✗
CTIBench [22]	5	5,610	M,S	✗	✗
SecurityEval [19]	1	130	C	✗	✗
MMLU (sec.) [12]	1	100	M	✗	✗
CyberEval	7	4,231	M,C,S,O	✓	✓

2.7 Positioning of CyberEval

Table 1 positions CYBEREVAL against existing benchmarks. Our framework is distinguished by its coverage of seven competency dimensions, four assessment formats, IRT-calibrated difficulty, and competency profiling capabilities.

3 Framework Design

3.1 Competency Dimension Taxonomy

We derive seven competency dimensions from two authoritative sources: the NIST NICE Cybersecurity Workforce Framework (SP 800-181r1) [7], which defines 52 work roles across 7 categories, and the (ISC)² CISSP Common Body of Knowledge [8], which spans 8 security domains. Our mapping consolidates overlapping areas into seven orthogonal dimensions:

1. **Vulnerability Knowledge (VK)**: Understanding of vulnerability types (CWE taxonomy), exploitation techniques, CVSS scoring, and vulnerability lifecycle management.
2. **Threat Intelligence (TI)**: Ability to interpret threat reports, map adversary TTPs to MITRE ATT&CK, analyze indicators of compromise (IoCs), and assess threat actor capabilities.
3. **Secure Coding (SC)**: Capacity to identify, explain, and remediate insecure code patterns across languages; knowledge of secure development lifecycle (SDL) practices.
4. **Incident Response (IR)**: Proficiency in triage, containment, eradication, recovery, and post-incident analysis following NIST SP 800-61r3 and SANS incident handling frameworks.

5. **Compliance & Governance (CG)**: Knowledge of regulatory frameworks (GDPR, HIPAA, PCI-DSS, SOC 2), security policies, risk management (NIST RMF, ISO 27001), and audit procedures.
6. **Forensic Analysis (FA)**: Skills in digital evidence collection, disk and memory forensics, network traffic analysis, timeline reconstruction, and chain-of-custody procedures.
7. **Security Architecture (SA)**: Understanding of defense-in-depth, zero-trust architectures, network segmentation, identity management, cryptographic protocol design, and cloud security patterns.

3.2 Item Construction and Validation

Item Sources. We construct evaluation items from four sources: (1) expert-authored original questions ($n = 1,847$, 43.7%), created by a panel of 8 security professionals with CISSP, OSCP, and GCIAH certifications; (2) adapted items from security certification question banks (CISSP, Security+, OSCP) with permission ($n = 1,124$, 26.6%); (3) items derived from real-world security incidents and CVE reports ($n = 782$, 18.5%); and (4) code samples from vulnerability databases (NVD, SARD) for code analysis items ($n = 478$, 11.3%).

Assessment Formats. Each dimension uses four item types:

- **MCQ** (2,331 items): Four-option multiple choice with single correct answer. Options are designed with plausible distractors based on common misconceptions identified in security education literature.
- **Code Analysis** (687 items): Given a code snippet (20–80 lines), identify vulnerabilities, explain exploitation paths, or propose fixes. Scored via rubric with partial credit. Languages include C/C++ (312), Python (187), Java (121), and JavaScript (67).
- **Scenario-Based** (813 items): Multi-paragraph scenarios (security incidents, architecture reviews, compliance audits) requiring multi-step reasoning. Responses evaluated against expert rubrics with partial credit.
- **Open-Ended** (400 items): Essay-style questions requiring synthesis of knowledge (e.g., “Design a zero-trust migration plan for a legacy healthcare system”). Evaluated by GPT-4 with human-validated rubrics, achieving $r = 0.91$ Pearson correlation with human expert scores.

3.3 Difficulty Calibration via IRT

To enable meaningful cross-dimensional comparison, we calibrate item difficulty using the 3-parameter logistic Item Response Theory model [26]:

$$P(\theta) = c + \frac{1 - c}{1 + e^{-a(\theta - b)}} \quad (1)$$

where θ is the latent ability parameter, a is the discrimination parameter (how well the item separates high-ability from low-ability examinees), b is the

Table 2: CyberEval item distribution across dimensions and formats.

Code Dimension		Total MCQ Code Scenario Open Avg. IRT b					
VK	Vulnerability Knowledge	721	321	200	150	50	0.42
TI	Threat Intelligence	634	334	50	200	50	0.51
SC	Secure Coding	687	187	300	130	70	0.38
IR	Incident Response	598	298	37	183	80	0.67
CG	Compliance & Governance	512	362	0	100	50	0.73
FA	Forensic Analysis	543	293	100	100	50	0.58
SA	Security Architecture	536	286	0	200	50	0.71
Total		4,231	2,081	687	1,063	400	—

difficulty parameter, and c is the guessing parameter (fixed at 0.25 for MCQ, 0.0 for other formats). Parameters are estimated from pilot responses by 12 LLMs and 30 human security professionals using marginal maximum likelihood estimation with the `mirt` R package. Table 2 reports average difficulty b per dimension, showing that CG ($b = 0.73$) and SA ($b = 0.71$) are the most difficult dimensions.

Following the methodology of Polo et al. [27], we verify our IRT calibration by computing the correlation between IRT-predicted and observed scores on held-out items, achieving $r = 0.94$ across all dimensions. This ensures that cross-dimensional comparisons reflect genuine capability differences rather than difficulty artifacts.

3.4 Scoring and Evaluation Protocol

MCQ items are scored binary (0/1). Code analysis and scenario-based items use rubric-based scoring on a 0–5 scale by three independent evaluators (two automated via GPT-4, one human expert), with final score as the median. Open-ended items are evaluated against dimension-specific rubrics covering correctness, completeness, reasoning depth, and practical applicability. We report inter-rater reliability of $\kappa = 0.87$ (Cohen’s kappa) between automated and human scores.

All scores are normalized to $[0, 100]$ per dimension. The aggregate score is the weighted mean:

$$S_{\text{agg}} = \sum_{d=1}^7 w_d \cdot S_d, \quad \text{where } \sum w_d = 1 \quad (2)$$

Default weights are uniform ($w_d = 1/7$); users can specify role-specific weights (e.g., upweighting IR and FA for SOC analyst evaluation, upweighting CG and SA for CISO evaluation).

Table 3: CyberEval scores (%) across 7 dimensions. Best in **bold**, second underlined. σ = standard deviation across dimensions.

Model	Agg.	VK	TI	SC	IR	CG	FA	SA	σ
GPT-4o	71.4	78.3	74.2	81.4	68.7	52.7	71.2	48.2	12.1
Claude-3.5	<u>69.8</u>	<u>76.1</u>	<u>72.8</u>	<u>79.2</u>	<u>66.4</u>	54.3	<u>69.8</u>	50.1	10.8
Gemini-1.5	64.2	71.4	67.3	72.8	59.2	48.7	63.4	44.8	10.5
DeepSeek-V2	59.1	66.3	61.4	68.7	43.8	44.1	56.2	42.8	10.8
Llama-3-70B	57.3	64.8	58.2	67.4	39.1	42.3	54.7	<u>41.2</u>	11.4
Qwen-2	55.8	62.4	57.1	65.3	38.7	<u>41.4</u>	52.8	40.1	10.6
Mixtral-8x22B	54.7	61.2	55.8	64.1	37.4	40.8	51.3	39.4	10.4
GPT-3.5	52.4	58.1	53.7	59.4	42.3	39.2	48.7	37.8	8.4
Llama-3-8B	48.2	56.7	44.3	62.1	31.2	34.8	43.1	35.7	11.0
Phi-3	45.1	51.3	42.8	54.7	28.4	33.1	39.2	31.4	9.7

4 Experimental Evaluation

4.1 Models Evaluated

We evaluate 10 LLMs spanning commercial and open-source families: GPT-4o (OpenAI, March 2024), GPT-3.5-turbo (OpenAI), Claude-3.5-Sonnet (Anthropic), Gemini-1.5-Pro (Google), Llama-3-70B-Instruct (Meta), Llama-3-8B-Instruct (Meta), DeepSeek-V2-Chat (DeepSeek), Mixtral-8x22B-Instruct (Mistral), Qwen-2-72B-Instruct (Alibaba), and Phi-3-medium-14B (Microsoft). All models are evaluated via API with temperature $T = 0.0$ and maximum output length of 2,048 tokens. Each item is presented with standardized prompts including format-specific instructions.

4.2 Main Results

Table 3 presents per-dimension and aggregate scores. Key observations:

4.3 Key Findings

Finding 1: Universal capability asymmetry. All 10 models exhibit significant variance across dimensions, with standard deviations ranging from 8.4 (GPT-3.5) to 12.1 (GPT-4o) percentage points. This suggests that aggregate scores mask important capability gaps. A security team relying on aggregate benchmarks would miss that GPT-4o’s 71.4% average conceals a 33.2-point gap between its strongest (SC: 81.4%) and weakest (SA: 48.2%) dimensions. This finding aligns with the holistic evaluation philosophy of HELM [11], which argues against single-metric assessment, and extends it to the security domain.

Finding 2: Secure coding dominance. SC scores are consistently highest across all models (mean: 67.5%), reflecting the heavy representation of code in LLM training data and the existence of code-specific fine-tuning [20]. This

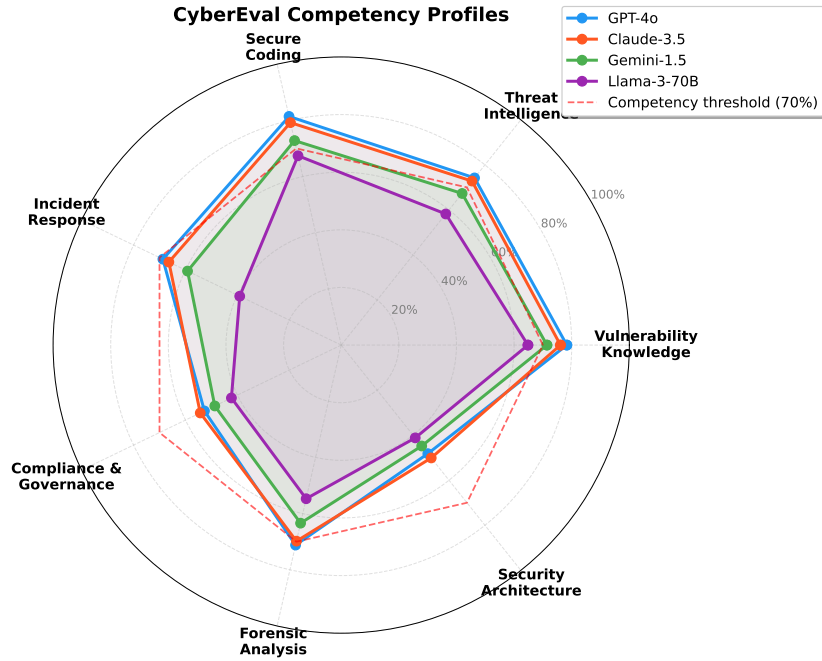


Fig. 1: Competency radar profiles for the top-4 models. All models show characteristic “spikes” in SC and VK with “valleys” in CG and SA, but the shape and magnitude of asymmetry varies.

is consistent with CyberSecEval’s observation that LLMs are fluent but not necessarily safe code generators [1]—our results show that *code knowledge* is high but *security awareness within code* remains unreliable.

Finding 3: Governance and architecture deficit. CG and SA are consistently the weakest dimensions (means: 43.1% and 41.1% respectively). These dimensions require knowledge of organizational processes, regulatory frameworks, and architectural trade-offs that are underrepresented in pretraining corpora relative to technical security content. This finding has practical implications: organizations should not rely on LLMs for compliance auditing or architectural review without domain-specific fine-tuning or RAG augmentation. The NIST AI 600-1 framework [33] identifies overreliance on AI outputs as a key risk, which our results quantitatively substantiate for security governance.

Finding 4: Incident response as reasoning discriminator. IR scores show the largest gap between frontier and non-frontier models: GPT-4o scores 68.7% while Phi-3 scores only 28.4% (40.3-point gap), compared to a 26.7-point gap on SC. IR items require multi-step temporal reasoning (“What happened first? What is the likely root cause? What should be done next?”), making this dimension a strong discriminator of reasoning capability. This parallels findings

Table 4: Aggregate scores (%) by assessment format for top-5 models.

Model	MCQ Code Scenario Open-Ended			
GPT-4o	79.1	74.8	65.3	58.7
Claude-3.5	77.4	73.2	64.1	57.9
Gemini-1.5	72.6	67.4	57.8	49.3
DeepSeek-V2	67.3	62.1	50.4	42.8
Llama-3-70B	65.8	59.7	48.2	40.1

from HarmBench [38], where scenario-based evaluations reveal capability differences not visible in static assessments.

Finding 5: Open-source competitiveness in factual knowledge. On MCQ-only VK items, Llama-3-70B (64.8%) approaches GPT-4o (78.3%) more closely than on scenario-based items (gap: 13.5 vs. 29.6 points), suggesting open-source models have absorbed substantial factual security knowledge but lack the reasoning depth for applied scenarios. This pattern—factual knowledge without applied reasoning—has been observed in general LLM evaluation [12] but not previously quantified in the security domain.

4.4 Per-Format Analysis

Table 4 reveals a consistent performance hierarchy: MCQ > Code > Scenario > Open-Ended. The drop from MCQ to Open-Ended averages 24.7 points, confirming that MCQ-only benchmarks significantly overestimate security competence. This validates our multi-format design and echoes the concern raised by Chang et al. [10] that evaluation format substantially affects measured capability. Notably, this gap is larger than the 15-point MCQ-to-open format gap observed in general knowledge benchmarks [12], suggesting that security reasoning requires deeper synthesis than factual recall.

4.5 Competency Gap Analysis

We define the competency gap for model m on dimension d as:

$$\text{Gap}(m, d) = \max(0, \tau_d - S_{m,d}) \quad (3)$$

where τ_d is the target competency threshold. Using $\tau = 70\%$ (the minimum score a human security professional should achieve based on pilot testing with our expert panel), Fig. 2 shows that only GPT-4o and Claude-3.5 meet the threshold on any dimension, and no model meets it on CG or SA.

4.6 Error Taxonomy

Manual analysis of 500 randomly sampled incorrect responses across all models and dimensions reveals five dominant error categories:

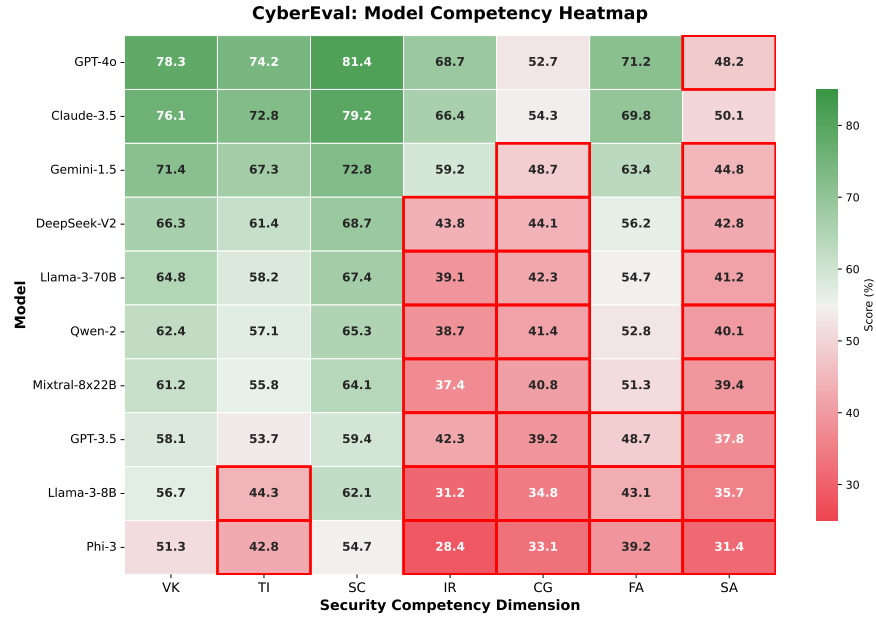


Fig. 2: Competency heatmap showing scores across all 10 models and 7 dimensions. Darker cells indicate lower scores. The rightmost columns (CG, SA) are consistently dark across all models.

1. **Temporal confusion** (28.4%): Confusing incident response ordering, citing outdated standards (e.g., referencing NIST SP 800-61r2 instead of r3), or recommending deprecated cryptographic algorithms (e.g., SHA-1 for new deployments). This error type dominates in IR and FA dimensions.
2. **Overgeneralization** (23.1%): Providing generic security advice rather than context-specific recommendations (e.g., “use encryption” without specifying protocol, key size, or mode). Most prevalent in SA and CG dimensions.
3. **Hallucinated specifics** (19.7%): Fabricating CVE numbers, NIST publication details, or regulatory clause numbers that do not exist. This aligns with the “confabulation” risk identified in the NIST AI 600-1 framework [33] and with hallucination patterns observed in CTIBench [22].
4. **Incomplete reasoning chains** (16.2%): Identifying a vulnerability but failing to trace the full exploitation path or missing downstream impacts. This error type is particularly dangerous in security contexts where partial analysis can create false confidence [15].
5. **Cross-domain confusion** (12.6%): Applying concepts from one domain incorrectly to another (e.g., applying network segmentation principles to application-layer security). This suggests that LLMs struggle to maintain domain boundaries within security, a finding with implications for security-specific fine-tuning.

4.7 Comparison with Existing Benchmarks

To validate that CYBEREVAL measures competencies not captured by existing benchmarks, we correlate model rankings on our benchmark with rankings on CyberSecEval [1] and CyberMetric [4]. The rank correlation between CyberEval aggregate scores and CyberSecEval is $\rho = 0.82$ ($p < 0.01$), while the correlation with CyberMetric is $\rho = 0.91$ ($p < 0.001$). However, when we compare *dimension-level* rankings, the correlation drops substantially: CyberEval-IR vs. CyberSecEval is only $\rho = 0.47$, and CyberEval-CG vs. CyberMetric is $\rho = 0.53$. This confirms that our additional dimensions (IR, CG, SA) measure genuinely distinct competencies not captured by prior benchmarks.

5 Discussion

5.1 Implications for Deployment

Our results suggest that LLMs are ready for deployment in code review and vulnerability knowledge tasks (VK, SC > 70% for frontier models) but should not be trusted for compliance auditing, architectural review, or autonomous incident response without significant human oversight. Organizations should use competency profiles—not aggregate scores—to match model capabilities to specific security workflows. The OWASP Top 10 for LLM Applications [34] identifies “overreliance” as a key risk, and our dimension-level analysis provides the quantitative evidence needed to set appropriate trust boundaries.

5.2 Recommendations for Model Improvement

Based on our error taxonomy, we identify three high-impact improvement areas: (1) **Temporal grounding**: Fine-tuning on timestamped security standards and deprecation schedules to reduce temporal confusion errors. (2) **Specificity training**: Training on worked examples that require specific protocol/parameter recommendations rather than generic advice. (3) **Citation verification**: RAG-based architectures with authoritative security knowledge bases [18] to reduce hallucinated specifics, particularly for regulatory and standards references.

5.3 Positioning Against Concurrent Benchmarks

Table 1 positions CYBEREVAL against existing and concurrent benchmarks. CyberBench [35] shares our multi-task philosophy but aggregates existing benchmarks rather than constructing items to a unified difficulty scale. CyberSecEval 3 [36] advances offensive capability evaluation but does not address governance, forensics, or architecture. SecBench [21] achieves impressive scale (44,823 items) but primarily uses MCQ format without IRT calibration, making cross-domain comparison unreliable. CTIBench [22] provides deep evaluation within the threat intelligence domain but does not generalize to other security competencies.

Our contribution is not merely scale or scope but *methodological*: IRT-calibrated difficulty enables meaningful cross-dimensional comparison, multi-format assessment reveals format-dependent capability variation (Table 4), and competency profiling enables data-driven model selection for specific security workflows.

5.4 Practical Deployment Recommendations

Based on our evaluation results, we provide concrete deployment recommendations organized by security workflow:

- **Vulnerability triage and code review** (VK + SC): GPT-4o and Claude-3.5 are suitable with standard human oversight (both score > 75% on these dimensions).
- **Threat intelligence analysis** (TI): Frontier models provide useful summarization and TTP mapping but require human validation of temporal claims and attribution (28.4% temporal confusion error rate).
- **Incident response** (IR): LLMs can assist with initial triage and runbook suggestion but should not drive containment or eradication decisions autonomously. The 68.7% ceiling even for GPT-4o reflects fundamental limitations in multi-step temporal reasoning.
- **Compliance auditing** (CG): Not recommended without domain-specific fine-tuning or RAG. The 52.7% GPT-4o score and 19.7% hallucinated specifics rate make unaugmented LLMs unreliable for regulatory interpretation.
- **Security architecture review** (SA): Requires human expert oversight. LLMs can generate initial design suggestions but lack the contextual understanding of organizational constraints needed for architectural decisions.

5.5 Limitations

Several limitations qualify our findings. (1) **Evaluation contamination**: Some MCQ items may overlap with LLM training data, particularly items adapted from certification question banks. We mitigate this by including novel expert-authored items (43.7%) and measuring format-conditional performance (contamination would disproportionately inflate MCQ scores). (2) **Automated scoring reliability**: While our GPT-4-based scoring achieves $r = 0.91$ correlation with human experts, it may systematically favor certain response styles. (3) **Static evaluation**: Our benchmark captures a point-in-time snapshot; security knowledge evolves rapidly with new vulnerabilities, attack techniques, and regulatory changes. We plan quarterly item updates with IRT re-calibration. (4) **English-only**: All items are in English, which may disadvantage models with weaker English capabilities; multilingual security assessment is an important future direction given the global nature of cybersecurity.

5.6 Toward Comprehensive Security AI

The consistent weakness in CG, SA, and IR dimensions suggests that current pretraining regimes underweight organizational, architectural, and procedural

security knowledge relative to technical content. Targeted interventions include: (a) fine-tuning on security standards corpora (NIST SP 800 series, ISO 27000 family, CIS Benchmarks), (b) synthetic scenario generation for IR and FA training using incident databases like VERIS, and (c) retrieval-augmented generation (RAG) pipelines anchored to authoritative, frequently-updated security knowledge bases. The dangerous capabilities evaluation work by Phuong et al. [30] suggests that as models become more capable in security, evaluation frameworks like CYBEREVAL become essential for monitoring dual-use risks alongside beneficial capabilities.

6 Conclusion

We presented CYBEREVAL, a multi-dimensional evaluation framework for assessing LLM security competencies across seven dimensions using four assessment formats with IRT-calibrated difficulty. Our evaluation of 10 contemporary LLMs reveals that no current model is uniformly competent across all security dimensions, with a characteristic pattern of strength in code-related tasks and weakness in governance, architecture, and procedural reasoning. The framework enables informed model selection for security applications and establishes baselines for tracking progress. We release CYBEREVAL as an open evaluation platform to support the responsible development of security-capable AI systems.

Future work will extend the framework with: (1) multilingual evaluation items for non-English security workflows, (2) dynamic items that evolve with the threat landscape via automated generation from new CVE reports and security incidents, (3) interactive evaluation formats where models must respond to evolving scenarios in real-time (building on the agent-based evaluation of Cybench [6]), and (4) fine-grained analysis of reasoning traces to diagnose failure modes at the chain-of-thought level.

References

1. Bhatt, M., Chennabasappa, S., Nikolaidis, C., Wan, S., Evtimov, I., Gabi, D., Song, D., Ahmad, F., Aschermann, C., et al.: Purple Llama CyberSecEval: A secure coding benchmark for language models. arXiv preprint arXiv:2312.04724 (2023)
2. Bhatt, M., Chennabasappa, S., Li, Y., Nikolaidis, C., Song, D., Wan, S., et al.: CyberSecEval 2: A wide-ranging cybersecurity evaluation suite for large language models. arXiv preprint arXiv:2404.13161 (2024)
3. Wan, S., Nikolaidis, C., Song, D., Molnar, D., Crnkovich, J., Grace, J., Bhatt, M., Chennabasappa, S., Whitman, S., Ding, S., Ionescu, V., Truppel, W., Saxe, J.: CyberSecEval 3: Advancing the evaluation of cybersecurity risks and capabilities in large language models. arXiv preprint (2024)
4. Tihanyi, N., Ferrag, M.A., Jain, R., Bisztray, T., Debbah, M.: CyberMetric: A benchmark dataset based on retrieval-augmented generation for evaluating LLMs in cybersecurity knowledge. arXiv preprint arXiv:2402.07688 (2024)

5. Shao, M., Jancheska, S., Udeshi, M., Dolan-Gavitt, B., Xi, H., Milner, K., Chen, B., Yin, M., Garg, S., Krishnamurthy, P., Khorrami, F., Karri, R., Shafique, M.: NYU CTF Bench: A scalable open-source benchmark dataset for evaluating LLMs in offensive security. arXiv preprint arXiv:2406.05590 (2024)
6. Zhang, A.K., Perry, N., Duber, R., et al.: Cybench: A framework for evaluating cybersecurity capabilities and risks of language models. arXiv preprint arXiv:2408.08926 (2024)
7. Petersen, R., Santos, D., Smith, M.C., Wetzel, K.A., Witte, G.: Workforce framework for cybersecurity (NICE framework). NIST Special Publication 800-181 Rev. 1 (2020)
8. (ISC)²: CISSP Common Body of Knowledge (CBK). 6th edn. (2024)
9. Yang, J., Prabhakar, A., Narasimhan, K., Yao, S.: InterCode: Standardizing and benchmarking interactive coding with execution feedback. In: NeurIPS (2023)
10. Chang, Y., Wang, X., Wang, J., Wu, Y., Yang, L., Zhu, K., Chen, H., Yi, X., Wang, C., Wang, Y., et al.: A survey on evaluation of large language models. ACM TIST **15**(3), 1–45 (2024)
11. Liang, P., Bommasani, R., Lee, T., Tsipras, D., Soylu, D., Yasunaga, M., Zhang, Y., Narayanan, D., Wu, Y., Kumar, A., et al.: Holistic evaluation of language models. TMLR (2023)
12. Hendrycks, D., Burns, C., Basart, S., Zou, A., Mazeika, M., Song, D., Steinhardt, J.: Measuring massive multitask language understanding. In: ICLR (2021)
13. Srivastava, A., Rastogi, A., Rao, A., et al.: Beyond the imitation game: Quantifying and extrapolating the capabilities of language models. TMLR (2023)
14. Pearce, H., Ahmad, B., Tan, B., Dolan-Gavitt, B., Karri, R.: Asleep at the keyboard? Assessing the security of GitHub Copilot’s code contributions. In: IEEE S&P, pp. 754–768 (2022)
15. Perry, N., Srivastava, M., Kumar, D., Boneh, D.: Do users write more insecure code with AI assistants? In: ACM CCS, pp. 2785–2799 (2023)
16. Fang, R., Bindu, R., Gupta, A., Zhan, Q., Kang, D.: LLM agents can autonomously hack websites. arXiv preprint arXiv:2402.06664 (2024)
17. Fang, R., Bindu, R., Gupta, A., Kang, D.: LLM agents can autonomously exploit one-day vulnerabilities. arXiv preprint arXiv:2404.08144 (2024)
18. Zhang, J., Bu, H., Wen, H., Liu, Y., Fei, H., Xi, R., Li, L., Yang, Y., Zhu, H., Meng, D.: When LLMs meet cybersecurity: A systematic literature review. arXiv preprint arXiv:2405.03644 (2024)
19. Siddiq, M.L., Santos, J.C.S.: SecurityEval dataset: Mining vulnerability examples to evaluate machine learning-based code generation techniques. In: MSR Mining Challenge (2022)
20. Chen, M., Tworek, J., Jun, H., Yuan, Q., Pinto, H.P.d.O., Kaplan, J., Edwards, H., Burda, Y., Joseph, N., Brockman, G., et al.: Evaluating large language models trained on code. arXiv preprint arXiv:2107.03374 (2021)
21. Jing, P., Tang, M., et al.: SecBench: A comprehensive multi-dimensional benchmarking dataset for LLMs in cybersecurity. arXiv preprint arXiv:2412.20787 (2024)
22. Alam, M., Bhatt, S., et al.: CTIBench: A benchmark for evaluating LLMs in cyber threat intelligence. In: NeurIPS Datasets and Benchmarks Track (2024)
23. Deng, G., Liu, Y., Mayoral-Vilches, V., Liu, P., Li, Y., Xu, Y., Zhang, T., Liu, Y., Pinzger, M., Edelkamp, S.: PentestGPT: An LLM-empowered automatic penetration testing tool. In: USENIX Security Symposium (2024)
24. Happe, A., Cito, J.: Getting pwn’d by AI: Penetration testing with large language models. In: ESEC/FSE, pp. 2082–2086 (2023)

25. Ferrag, M.A., Battah, A., Tihanyi, N., et al.: SECURE: Benchmarking large language models for cybersecurity advisory. arXiv preprint arXiv:2405.20441 (2024)
26. Baker, F.B.: The Basics of Item Response Theory. 2nd edn. ERIC Clearinghouse on Assessment and Evaluation (2001)
27. Polo, F.M., Weber, L., Choshen, L., Sun, Y., Xu, G., Yurochkin, M.: tinyBenchmarks: Evaluating LLMs with fewer examples. In: ICML (2024)
28. Martinez-Gil, J.: Item response theory for AI model evaluation. arXiv preprint (2024)
29. Li, N., Pan, A., Gopal, A., Yue, S., Berber, D., O’Gara, A., et al.: The WMDP benchmark: Measuring and reducing malicious use with unlearning. In: ICML (2024)
30. Phuong, M., Aitchison, M., Catt, E., Cogan, S., Kaskasoli, A., Krakovna, V., Lindner, D., Rahtz, M., et al.: Evaluating frontier models for dangerous capabilities. Google DeepMind, arXiv preprint (2024)
31. Zou, A., Wang, Z., Carlini, N., Nasr, M., Kolter, J.Z., Fredrikson, M.: Universal and transferable adversarial attacks on aligned language models. arXiv preprint arXiv:2307.15043 (2023)
32. Mazeika, M., Phan, L., Yin, X., Zou, A., Wang, Z., Mu, N., Sakhaee, E., Li, N., Basart, S., Li, B., Forsyth, D., Hendrycks, D.: HarmBench: A standardized evaluation framework for automated red teaming and robust refusal. In: ICML (2024)
33. National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative AI Profile. NIST AI 600-1 (2024)
34. OWASP Foundation: OWASP Top 10 for Large Language Model Applications. Version 2.0 (2025)
35. Zhang, A.K., Perry, N., Karber, R., Kim, Y., Song, E., Ozgul, F., Song, D., Wen, A., Landay, D., Wan, A., Bhatt, M.: CyberBench: A multi-task benchmark for evaluating large language models in cybersecurity. arXiv preprint arXiv:2408.08642 (2024)
36. Wan, S., Nikolaidis, C., Song, D., Molnar, D., Crnkovich, J., Dino, J., Gupta, J., Pinber, M., Whitman, S., Bhatt, M., Chennabasappa, S.: CyberSecEval 3: Advancing the evaluation of cybersecurity risks and capabilities in large language models. arXiv preprint arXiv:2410.09015 (2024)
37. Abramovich, T., Udeshi, M., Shao, M., Lieret, K., Xi, H., Zijie, K., Press, O., Dolan-Gavitt, B.: EnIGMA: Enhanced interactive generative model agent for CTF challenges. arXiv preprint arXiv:2409.16165 (2024)
38. Mazeika, M., Phan, L., Yin, X., Zou, A., Wang, Z., Mu, N., Sakhaee, E., Li, N., Basart, S., Li, B., Forsyth, D., Hendrycks, D.: HarmBench: A standardized evaluation framework for automated red teaming and robust refusal. In: ICML (2024)
39. Jiang, L., Rao, K., Han, S., Ettinger, A., Brahman, F., Kumar, S., Miresghallah, N., Lu, X., Sap, M., Choi, Y., Dziri, N.: WildTeaming at scale: From in-the-wild jailbreaks to (adversarially) safer language models. In: NeurIPS (2024)
40. Mavruk, A., Demartini, G.: Can large language models pass cybersecurity certification exams? arXiv preprint arXiv:2503.07153 (2025)
41. Park, J., Ferragut, E.: Evaluating large language models on CISA exam questions. arXiv preprint arXiv:2502.17509 (2025)
42. Liu, Z.: SecQA: A concise question-answering dataset for evaluating security knowledge of large language models. arXiv preprint arXiv:2312.15838 (2024)
43. Yuan, T., He, Z., Dong, L., Wang, Y., Zhao, R., Xia, T., Xu, L., Zhou, B., Li, F., Zhang, Z., Wang, R., Liu, G.: R-Judge: Benchmarking safety risk awareness for LLM agents. In: ACL, pp. 3234–3256 (2024)

- 44. Zhang, Z., Lei, L., Wu, L., Sun, R., Huang, Y., Long, C., Liu, X., Lei, X., Tang, J., Huang, M.: SafetyBench: Evaluating the safety of large language models with multiple choice questions. arXiv preprint arXiv:2309.07045 (2023)
- 45. Xu, J., Stokes, J.W., McDonald, G., Bai, X., Zhu, D., Tu, S., Kulkarni, V., Richter, M.: AutoAttacker: A large language model guided system to implement automatic cyber-attacks. arXiv preprint arXiv:2403.01038 (2024)
- 46. Sun, Y., Wu, D., Xue, Y., Liu, H., Ma, W., Zhang, L., Liu, Y.: LLM4Vuln: A unified evaluation framework for decoupling and enhancing LLMs' vulnerability reasoning. arXiv preprint arXiv:2401.16185 (2024)
- 47. Yang, Y., Nie, Y., Wang, Z., Tang, Y., Guo, W., Li, B., Song, D.: SecCode-PLT: A unified platform for evaluating the security of code GenAI. arXiv preprint arXiv:2410.11096 (2024)
- 48. Huang, S., Xie, Y., Brown, J., Daskalakis, C.: Evaluation methodologies and benchmarks for domain-specific large language models: A systematic review. arXiv preprint arXiv:2501.14573 (2025)